

Third-party management, IT outsourcing and EBIOS RM (Workshops 3-4)

✓ From design to the control of the third parties already there

The IT outsourcing contract

keep the incumbent third party in check

Workshops 3 and 4

tell where it could betray

Third-party control

Session objectives

By the end of this tutorial:

- **Analyze** an IT outsourcing contract from the security angle, and spot what is missing from an existing service of the group
- **Build** the ecosystem dangerousness map of a MERIDIAN studied object and select its critical stakeholders
- **Develop** a strategic scenario, from the risk origin to the feared event, through a critical stakeholder

Prerequisites

- This morning's lecture: Security by Design, security milestones, and the three regimes buy / develop / have developed.
- The session 5 risk assessment: the D5 file, with the framing, the justified severity and likelihood scales, the security baseline, the business assets and supporting assets taken over from session 2, and the risk origin / target objective (RO/TO) pairs retained in Workshops 1 and 2.
- The session 2 mapping: its ecosystem view is the direct input of Workshop 3.
- The session 4 audit report, whose deviations feed the security baseline.
- The contract extract of the subsidiary under review, provided in the reference pack (subfolder "Outsourcing-contracts") and online under /assets/tp/contrats/.

✓ What to set down before handling anything

Ten minutes of framing, no more. This morning's lecture integrated security into projects; this tutorial deals with the durably installed third parties, the ones the "have developed or outsource" regime designates, and it enters Workshops 3 and 4 of the risk analysis method, from the ecosystem angle. Three notions to set down, which the lecture left aside.

The outsourcing contract first. IT outsourcing (infogérance), according to the ANSSI (the French national cybersecurity agency) guide « Maîtriser les risques de l'infogérance » (mastering outsourcing risks), is « l'externalisation appliquée au domaine des systèmes d'information » (outsourcing applied to the field of information systems), that is, « confier à un tiers tout ou partie d'une activité qui jusqu'alors était réalisée en interne » (entrusting to a third party all or part of an activity that until then was performed in-house). The outsourcing contract is the act that governs this delegation.

Its security mechanics fit in one idea the guide hammers home: what is not required in the contract will never be owed. The client organization assesses its risks, derives security requirements from them, writes them into the specifications, and asks the candidates for a contractual document, the Security Assurance Plan (Plan d'Assurance Sécurité), which « décrit l'ensemble des dispositions spécifiques que les candidats s'engagent à mettre en œuvre

pour garantir le respect des exigences de sécurité du donneur d'ordres » (describes the whole set of specific provisions the candidates commit to implementing to guarantee compliance with the client's security requirements).

Four requirements come back everywhere and form the backbone of a secure outsourcing contract: reversibility (being able to « reprendre la gestion de la fonction externalisée, soit pour l'exploiter directement, soit pour en confier l'exploitation à un tiers de son choix », to take back the management of the outsourced function, either to operate it directly or to entrust its operation to a third party of one's choosing), the right to audit (« Le client doit pouvoir, à tout moment, contrôler que les exigences de sécurité sont satisfaites », the client must be able, at any time, to check that the security requirements are met), incident notification (« le client doit être tenu informé sans délai en cas d'attaque afin de déclencher le circuit de réaction adéquat », the client must be kept informed without delay in the event of an attack in order to trigger the appropriate reaction circuit), and the control of subcontracting (reserving « le droit de récuser tout sous-traitant ne présentant pas les garanties suffisantes », the right to reject any subcontractor not offering sufficient guarantees). The limit: a contract perfect on paper is only worth the follow-up committee that keeps it alive and the audits that verify it.

Secure IT outsourcing contract

Reversibility

**Right to
audit**

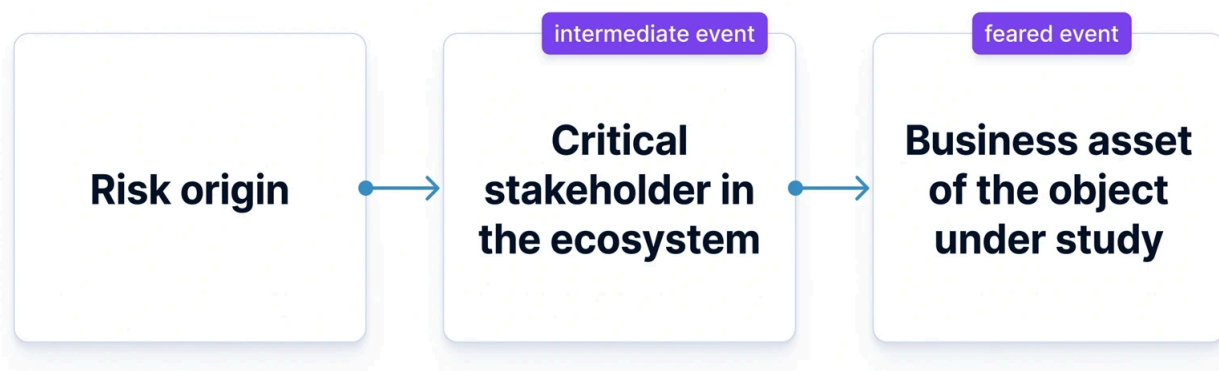
**Incident
notification**

**Subcontracting
oversight**

Workshops 3 and 4 of the method, next, approached here and this afternoon. Session 5 presented the first two workshops of EBIOS Risk Manager: Workshop 1 framed the study, set the business assets, the supporting assets, the feared events and the security baseline; Workshop 2 identified the risk origin / target objective pairs. **Workshop 3** takes over: according to the guide, « L'objectif de l'atelier 3 est de disposer d'une vision claire de l'écosystème, afin d'identifier et de présenter les parties prenantes les plus menaçantes à la direction. Il s'agit ensuite de bâtir des scénarios de haut niveau, appelés scénarios stratégiques. » (The objective of Workshop 3 is to have a clear vision of the ecosystem, in order to identify the most threatening stakeholders and present them to management. High-level scenarios, called strategic scenarios, are then built.) Its mechanics: the dangerousness of

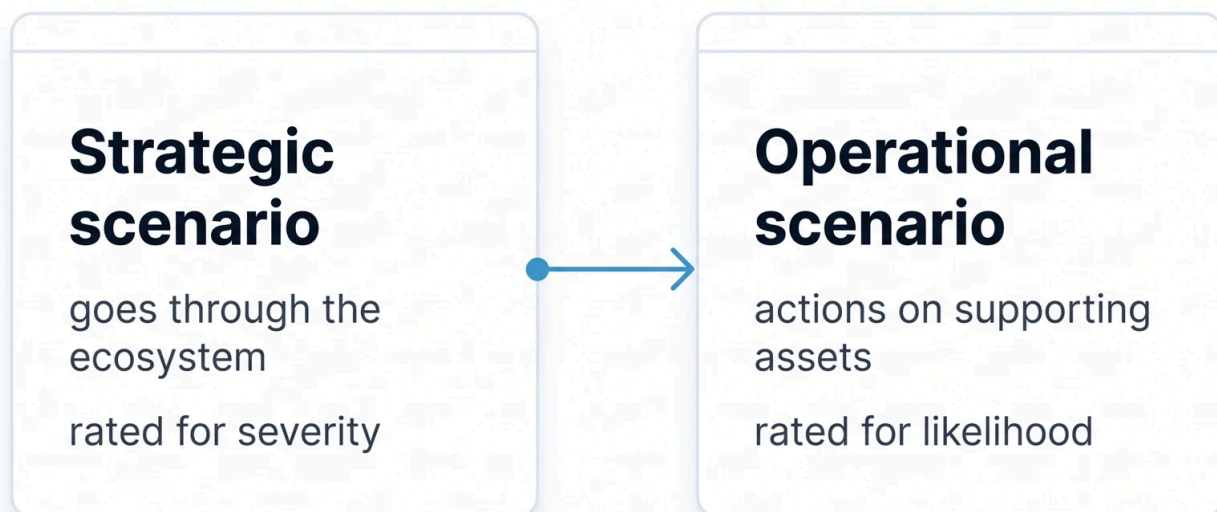
each stakeholder in the ecosystem is estimated, the critical stakeholders are selected from them, then attack paths are traced for each RO/TO pair.

A **critical stakeholder** is one « susceptible de constituer un vecteur d'attaque pertinent, du fait par exemple de son accès numérique privilégié à l'objet étudié, de sa vulnérabilité ou de son exposition » (likely to constitute a relevant attack vector, owing for example to its privileged digital access to the studied object, its vulnerability or its exposure). A **strategic scenario** is, according to the guide's glossary, a set of « chemins d'attaque allant d'une source de risque à un objectif visé en passant par l'écosystème et les valeurs métier de l'objet étudié » (attack paths going from a risk origin to a target objective through the ecosystem and the business assets of the studied object), and it « est estimé en termes de gravité » (is estimated in terms of severity). It is exactly this morning's pivot attack, formalized: the path that goes through the weak link of the ecosystem.



The strategic scenario is rated for severity

Workshop 4, finally, only touched on here, and which the afternoon will equip. Its purpose, according to the guide: « construire des scénarios opérationnels [qui] schématisent les modes opératoires que pourraient mettre en œuvre les sources de risque pour réaliser les scénarios stratégiques » (build operational scenarios [that] diagram the operating modes the risk origins could implement to carry out the strategic scenarios). An **operational scenario** is « un enchaînement d'actions élémentaires portées sur les biens supports » (a sequence of elementary actions carried out on the supporting assets), and it « est estimé en termes de vraisemblance » (is estimated in terms of likelihood). The link between the two workshops is clear-cut: « À chaque chemin d'attaque stratégique retenu dans l'atelier 3 correspond un scénario opérationnel. » (To each strategic attack path retained in Workshop 3 corresponds an operational scenario.) The strategic scenario says where the attack passes (the ecosystem); the operational scenario says how it is done technically (the supporting assets).



Each attack path maps to one operational scenario

One figure to measure the stakes before acting: according to the 2022 CESIN (the French club of information security experts) barometer, 24% of companies cited the pivot attack via a service provider among the transmission channels of the attacks they had suffered. The critical stakeholder is not a methodological abstraction: it is a real, measured entry door.

Everything is in place: a contract to hold a third party, a method to tell where it could betray the group. The exercises run through this chain, from contract to scenario.

Exercise 1: the contract of the most exposed provider of the subsidiary under review (15 minutes)

Take up the contract extract of the most exposed provider of the subsidiary under review, provided for each subsidiary in the "Outsourcing-contracts" subfolder of the reference pack and under /assets/tp/contrats/. What the extract does not stipulate, the contract does not stipulate. From the four families of requirements of a secure outsourcing contract, reversibility, right to audit, incident notification and control of subcontracting, establish for this contract the verifiable requirements that are missing and the gap each one corrects, relying on the extract and on what the subsidiary pack establishes. Word verifiable requirements, not legal clauses.

To produce: a three-column table, family, verifiable requirement, gap corrected, plus a free row for the most urgent requirement, justified in one sentence.

✓ Exercise 2: the dangerousness map and a strategic scenario (20 minutes)

Take as the studied object the number one critical asset of the subsidiary under review, the business asset whose feared event is rated highest in the D5 file. Read its ecosystem in §3 and §6 of the subsidiary pack and retain at least four stakeholders. Estimate the dangerousness of each on exposure and cyber reliability, rank them, then designate the critical stakeholder or stakeholders according to a threshold the group sets and writes down. Then trace, for the risk origin / target objective pair retained in session 5, a strategic scenario that goes through a critical stakeholder, and rate its severity on the D5 scale, from G1 minor to G4 critical.

To produce: the ranked dangerousness map with its critical stakeholders designated, and a strategic scenario rated in severity.



Answer keys and assessment criteria – cliquer pour révéler